

A No-Brains-Needed Getshell on an SRC

By J0o1ey · Translated from the Chinese original

0x01 Preface

Friends interested in technical exchange or penetration testing training are welcome to contact me via QQ/WeChat: 547006660.

0x02 From Asset Collection to a Fragile System

While hunting on an SRC program, I collected domain assets from SSL certificates, weighted the IP ranges behind those domains to map out the Class C subnets, and ran a batch directory scan against them.

Reviewing the scan results, I spotted an interesting file:

```
http://36...*/upload_image.php
```



For a page like this, there is no question: FUZZ the parameters.

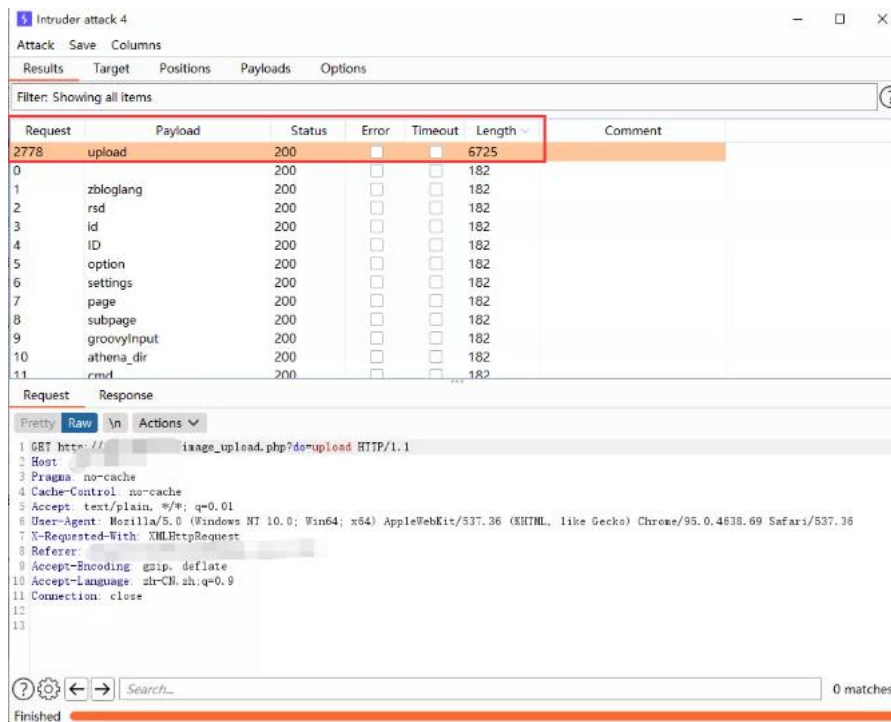
0x03 FUZZing Parameters + Form Upload

Using arjun to fuzz its parameters, I discovered one field: do

Then I fuzzed the value of the do parameter in Burp Suite.

```
ubuntu@VM-8-6-ubuntu:~$ arjun -u https://36
( _|_ ) v2.1.2
[*] Probing the target for stability
[*] Analysing HTTP response for anomalies
[*] Analysing HTTP response for potential parameter names
[*] Logicforcing the URL endpoint
[✓] name: do, factor: http code
ubuntu@VM-8-6-ubuntu:~$
```

Successfully fuzzed out a value for do: upload



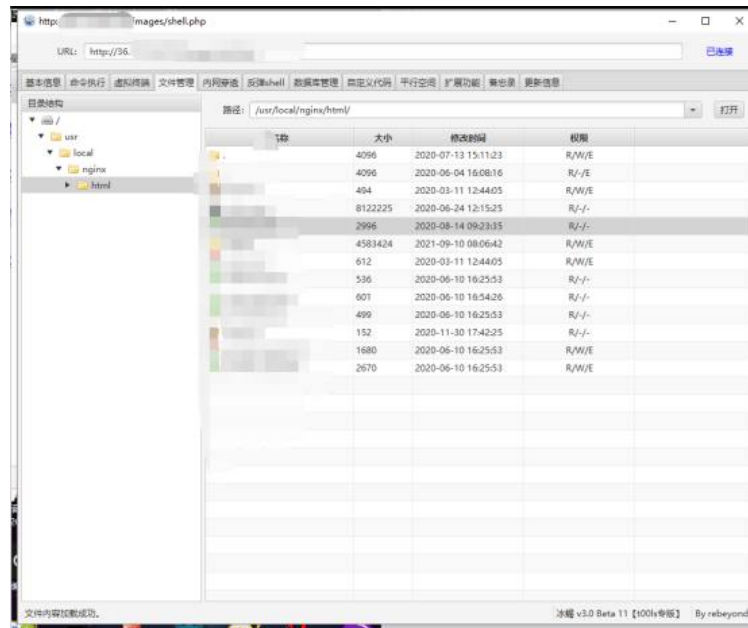
Constructing the URL `http://36...*/upload_image.php?do=upload` made the upload form appear.

My webshell's filename: `skr_anti.php`

I selected our webshell and uploaded it.

After the upload, I fuzzed for the upload path:

```
http://36.*.*.*upload --> 403, keep fuzzing
http://36.*.*.*upload/images --> 403, construct the URL
http://36.*.*.*upload/images/skr_anti.php
```



It happened to be during a double-bounty event — 8,000 RMB in the pocket.

0x04 Summary

I don't think anyone will object if I say this bug needed nothing but a pair of hands. Key takeaways:

1. When you hit a blank, sensitive-looking page or API, FUZZ its parameters and parameter values.
2. If the upload doesn't return a file path, don't panic — use your beautiful brain and FUZZ for it.
3. When testing on an SRC, do NOT upload a webshell — phpinfo is enough, or your bounty will be downgraded. I learned this the hard way... First time I've ever seen a program that forbids webshells.
4. Asset collection is the core of red teaming and penetration testing.